Đào tạo bảo mật thông tin

2021.12.06

- IT Part -



Mục lục

1. Định nghĩa chính sách bảo mật
2. Bối cảnh
3. Áp dụng và tuân thủ chính sách
4. Các trường hợp phát sinh sự cố thực tế
5. Biện pháp nâng cao bảo mật

Định nghĩa

❖ Chính sách bảo mật là:

- Là một tài liệu, tiêu chuẩn chung về hệ thống thông tin.

- Đưa ra quy định chung liên quan đến bảo mật hệ thống thông tin nhằm đảm bảo an ninh hệ thống thông tin.



❖ Tiêu chuẩn chung, chính sách cơ bản về bảo mật hệ thống thông tin

- Bảo mật hệ thống thông tin cần được cải tiến liên tục
- Nhân viên của SEMV phải hoàn thành trách nhiệm tương ứng với vai trò của mình, hiểu được tầm quan trọng của hệ thống thông tin
- Đánh giá tính nguy hiểm của hệ thống thông tin thông qua các mối đe dọa và rủi ro từ tính bảo mật

BỐI CẢNH

❖ Mục đích áp dụng:

- Để ngăn chặn những thiệt hại do rò rỉ thông tin

- Đảm bảo hoạt động kinh doanh, sản xuất của công ty, tập đoàn được xuyên suốt không bị gián đoạn

- Đảm bảo sự tin tưởng của khách hàng

- Hiểu rõ tầm quan trọng của hệ thống thông tin và tuân thủ bảo mật

=> Tuân thủ quy định và tăng cường thực hiện các hoạt động bảo mật hệ thống thông tin



Áp dụng và tuân thủ chính sách

❖ Kiểm soát truy cập

Người quản trị hệ thống

- Quản lý quyền truy cập theo cấp độ bảo mật (A, B, C…) đối với nhân viên trong công ty và vendor
- Quy định quy trình phân chia quyền, yêu cầu nhân viên thay đổi mật khẩu thường xuyên ngay cả khi ID người dùng được sử dụng liên tục.

Người dùng

- Người dùng không cung cấp thông tin tài khoản của mình cho người khác
- Không cho người khác mượn tài khoản
- Thay đổi mật khẩu định kì 3 tháng một lần, đặt mật khẩu đủ mạnh để đảm bảo bảo mật (mật khẩu gồm chữ, chữ hoa, số, ký tự đặc biệt, 8 ký tự trở lên)

Áp dụng và tuân thủ chính sách

❖ Kiểm soát, đối phó với mã độc hại

1. Quản trị viên

Cài đặt phần mềm đối phó với mã độc hại và hướng dẫn cho người dùng về biện pháp phòng ngừa.

2. Người dùng

- Định kì update phần mềm diệt virut và bản windows mới nhất.
- Không được dùng các chương trình không rõ nguồn, cách sử dụng.
- Kiểm tra mã độc (virut) trước khi trao đổi dữ liệu bên ngoài công ty.
- Báo cáo, tham khảo ý kiến của người phụ trách IT khi phát hiện ra hiện tượng đáng ngờ trong khi sử dụng, hoặc cho rằng có thể đã xảy ra sự cố bảo mật.

Khi bạn vờ như không thấy bất thường, thiệt hại có thể sẽ tăng lên nhiều lần.

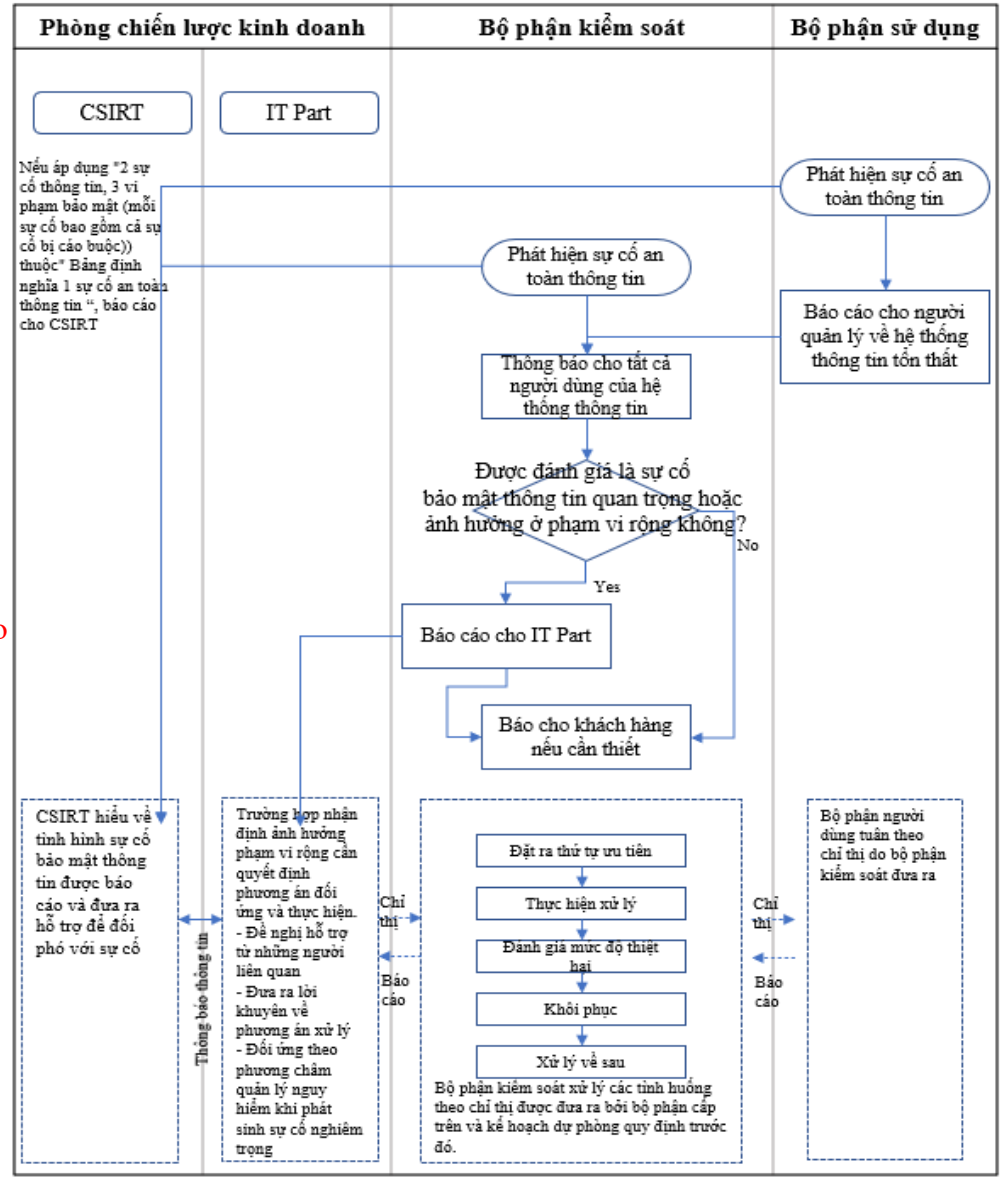
Áp dụng và tuân thủ chính sách

❖ Đối phó với sự cố bảo mật

Phân loại các sự cố bảo mật

No.	Phân loại	Nội dung	Nguyên nhân
1	Lỗi dịch vụ	Khó tiếp tục các ứng dụng, dịch vụ một cách bình thường	Lỗi phần cứng / phần mềm...
2	Lỗi thông tin	Tính xác thực của thông tin cần bảo vệ còn nhiều nghi vấn	Rò rỉ, thay đổi, phá hủy thông tin...
3	Vi phạm an ninh	Cố ý vi phạm các biện pháp bảo mật	Truy cập trái phép, lây nhiễm virut, bị hack mật khẩu...
4	Lỗi bảo mật	Các biện pháp bảo mật không được áp dụng hoặc không hiệu quả	Cài đặt tường lửa không đầy đủ, xử lý key không đúng cách, v.v.
5	Sự cố đáng ngờ	Nghi ngờ sự xuất hiện của các sự cố an ninh được mô tả từ 1 đến 4 mục trên	

Xử lý theo quy trình



Các trường hợp phát sinh sự cố thực tế

❖ Thiệt hại do sự cố bảo mật gây ra

1. **Thiệt hại do bị hack email** của các công ty thành viên thuộc tập đoàn Sumitomo
   Hacker lấy cắp nội dung email của công ty và khách hàng rồi giả dạng là đối tác kinh doanh của công ty và yêu cầu thanh toán các chi phí.
   Hacker đột nhập vào email của nhân viên tính lương rồi yêu cầu kế toán chuyển tiền.

2. **Ransomeware** là một chương trình độc hại xâm nhập vào máy tính hoặc hệ thống server, mã hóa các tệp quan trọng để ngăn người dùng truy cập, sau đó hacker sẽ đòi tiền 1 khoản tiền chuộc lớn.
   Colonial Pipeline, công ty vận hành đường ống dẫn dầu lớn nhất ở Mỹ, đã trả khoảng 5 triệu USD (khoảng 114 tỷ VND) cho nhóm hacker để lấy công cụ giải mã nhưng việc khôi phục dữ liệu chậm khiến cho việc vận hành nhà máy bị gián đoạn.

3. **Thủ đoạn lừa đảo liên quan đến tài chính, ngân hàng**
   Qua email, tin nhắn điện thoại, cuộc gọi... hacker mạo danh cán bộ cơ quan chức năng, qua website giả, các trang mạng xã hội khác, hacker giả dạng người thân, đối tác
   => sau đó yêu cầu/ nhờ chuyển khoản.

Biện pháp nâng cao bảo mật

Người dùng thực hiện những biện pháp dưới đây để nâng cao bảo mật hệ thống thông tin



1. Định kỳ update window để vá lỗi bảo mật
2. Không truy cập vào các đường link, liên kết không rõ nguồn gốc trong tin nhắn, email...
3. Không cung cấp thông tin cá nhân, tài khoản đăng nhập, mã xác thực OTP ... Cho bất kì cá nhân hay tổ chức nào mà chưa rõ quan hệ.
4. Không cài đặt các ứng dụng chưa được xác thực trên các kho ứng dụng.
5. Không cắm các thiết bị lạ vào máy tính.
6. Chủ động thay đổi mật khẩu thường xuyên, cài đặt mật khẩu đủ mạnh để đảm bảo bảo mật thông tin.
7. Khóa máy tính khi rời khỏi vị trí làm việc.

- THANK YOU -